

SLOVENSKÁ TECHNICKÁ UNIVERZITA V BRATISLAVE

Fakulta elektrotechniky a informatiky

Web skimming a krádež platobných údajov z e-shopov

Semestrálny projekt

Obsah

1	Úvod	5
1.1	Kontext problematiky	5
1.2	Cieľ a rozsah práce	6
1.3	Metodika a použité zdroje	6
2	Definícia web skimmingu	8
2.1	Pojem web skimming a základná definícia	8
2.2	Odlíšnosť od príbuzných foriem útokov	8
2.3	Typické znaky a rizikové prostredie	9
3	Technický princíp útoku	11
3.1	Základný priebeh web skimmingu	11
3.2	Vstupné body a kompromitácia stránky	12
3.3	Zachytávanie údajov v prehliadači používateľa	13
3.4	Odosielanie údajov a maskovanie útoku	13
3.5	Prečo je detekcia web skimmingu náročná	13
4	Kriminálna podstata a dopady útoku	15
4.1	Web skimming ako forma finančne motivovanej kriminality	15
4.2	Dopady na zákazníkov a zneužitie ukradnutých údajov	15
4.3	Dopady na prevádzkovateľov e-shopov a online služieb	16
4.4	Právny a regulačný rozmer incidentu	16
5	Prípadová štúdia: British Airways	18
5.1	Charakteristika incidentu	18
5.2	Technická a kriminálna stránka prípadu	18
5.3	Následky a význam prípadu	19
5.4	Zhrnutie prípadu British Airways	19
6	Prípadová štúdia: Ticketmaster	20
6.1	Charakteristika incidentu	20
6.2	Technická a kriminálna stránka prípadu	21
6.3	Následky a význam prípadu	21
6.4	Zhrnutie prípadu Ticketmaster	21
7	Prípadová štúdia: Newegg a Magecart	22
7.1	Charakteristika incidentu	22

7.2	Technická a kriminálna stránka prípadu	23
7.3	Následky a význam prípadu	23
7.4	Zhrnutie prípadu Newegg	24
8	Porovnanie prípadov	25
8.1	Spoločné znaky vybraných incidentov	25
8.2	Rozdiely medzi prípadmi	25
8.3	Komparatívna tabuľka	25
8.4	Vyhodnotenie a hlavné poučenia	25
9	Možnosti prevencie a ochrany	28
9.1	Ochrana platobnej stránky a správa skriptov	28
9.2	Technické opatrenia	28
9.3	Organizačné opatrenia a riadenie rizík	29
9.4	Opatrenia z pohľadu zákazníka	29
9.5	Prehľad ochranných opatrení	29
9.6	Zhrnutie ochrany	29
10	Záver	32
	Literatúra	33
	Použitie nástrojov umelej inteligencie	35

Zoznam značiek a skratiek

AI – umelá inteligencia, z angl. *Artificial Intelligence*

API – aplikačné programové rozhranie, z angl. *Application Programming Interface*

CDN – sieť na doručovanie obsahu, z angl. *Content Delivery Network*

CISA – americká Agentúra pre kybernetickú a infraštruktúrnú bezpečnosť, z angl. *Cybersecurity and Infrastructure Security Agency*

CSP – politika bezpečnosti obsahu, z angl. *Content Security Policy*

DDoS – distribuované odmietnutie služby, z angl. *Distributed Denial of Service*

EHP – Európsky hospodársky priestor

EÚ – Európska únia

FBI – Federálny úrad pre vyšetrovanie, z angl. *Federal Bureau of Investigation*

GDPR – všeobecné nariadenie o ochrane údajov, z angl. *General Data Protection Regulation*

HTTPS – zabezpečený protokol HTTP, z angl. *Hypertext Transfer Protocol Secure*

ICO – britský Úrad komisára pre informácie, z angl. *Information Commissioner's Office*

OWASP – projekt otvorenej webovej bezpečnosti, z angl. *Open Worldwide Application Security Project*

PCI DSS – bezpečnostný štandard pre odvetvie platobných kariet, z angl. *Payment Card Industry Data Security Standard*

SRI – integrita externých zdrojov, z angl. *Subresource Integrity*

1 Úvod

1.1 Kontext problematiky

Pri online nákupe zákazník zadáva do webových formulárov osobné, fakturačné a platobné údaje. Kombinácia finančných a osobných informácií robí z platobných stránok e-shopov atraktívny cieľ pre útočníkov. Útok pritom nemusí mať podobu výpadku služby alebo zničenia dát: pri web skimmingu môže stránka pre zákazníka fungovať bežne a ten si nemusí všimnúť, že jeho údaje boli počas nákupu skopírované a odoslané útočníkom [1, 2].

Web skimming, označovaný aj ako e-skimming, digital skimming, formjacking alebo Magecart, je forma počítačovej kriminality, pri ktorej útočníci vložia škodlivý kód do webovej stránky spracúvajúcej online platby. FBI uvádza, že prístup k webu môžu získať cez phishing voči zamestnancom alebo cez zraniteľného dodávateľa tretej strany. CISA opisuje vkladanie skimmingového kódu na platobné stránky e-commerce webov s cieľom zachytiť údaje z platobných kariet a osobne identifikovateľné informácie. Europol pojem digital skimming definuje ako krádež informácií o platobnej karte alebo platobných údajov zákazníkov online obchodu [1–3].

Dôležitým znakom web skimmingu je nenápadnosť. Pri klasickom phishingu je používateľ presmerovaný na falošnú stránku, no pri web skimmingu nakupuje na skutočnej stránke legitímneho obchodníka – problémom je kompromitovaný skript, ktorý zachytáva údaje z formulárov priamo v prehliadači používateľa. Bezpečnosť online platby preto nezávisí iba od banky alebo platobnej brány: rizikom môže byť aj samotná stránka obchodníka, jej JavaScript, externé knižnice, reklamné skripty, analytické nástroje či chatboty tretích strán. OWASP pri JavaScripte tretích strán upozorňuje najmä na stratu kontroly nad klientskou aplikáciou a riziko úniku citlivých údajov, čomu má napomôcť aj mechanizmus Subresource Integrity [1, 2, 4, 5].

Web skimming prepája technickú zraniteľnosť webovej aplikácie s priamym finančným zneužitím. Ukradnuté údaje môžu byť použité na neoprávnené platby, predané ďalším skupinám alebo kombinované s inými uniknutými údajmi pri krádeži identity. Práve táto väzba radí web skimming medzi závažné formy kybernetickej kriminality [1, 3, 6].

Závažnosť potvrdzujú aj známe prípady. V prípade British Airways britský regulátor ICO pôvodne oznámil zámer pokuty 183,39 milióna libier; konečná pokuta dosiahla 20 miliónov libier za nedostatočnú ochranu osobných a platobných údajov. Prípád Ticketmaster je dôležitý tým, že škodlivý kód súvisel s chatbotom tretej strany nasadeným

aj na platobných stránkach. Newegg je typickým príkladom Magecart útoku na veľký e-commerce web [7–10].

1.2 Cieľ a rozsah práce

Cieľom práce je vysvetliť web skimming ako konkrétny typ počítačovej kriminality, opísať jeho technický princíp, ukázať jeho prepojenie na krádež platobných údajov a porovnať vybrané prípady z praxe. Práca sa sústreďí na útoky, pri ktorých je hlavným mechanizmom vloženie škodlivého JavaScriptu do platobnej stránky alebo do skriptu, ktorý sa na nej načítava.

V prvej časti je vysvetlený pojem web skimming a jeho vzťah k príbuzným pojmom (e-skimming, digital skimming, formjacking, Magecart) a odlišnosť od phishingu či úniku databázy. Nasleduje technický princíp: ako sa útočník dostane k možnosti meniť skripty, ako kód zachytáva údaje a ako sú odosielané mimo prostredia obchodníka. Samostatná kapitola sa venuje kriminálnej podstate – web skimming nie je iba technická chyba, jeho výsledkom je neoprávnené získanie platobných a osobných údajov a útok zasahuje viac strán naraz: zákazníkov, obchodníkov, banky aj regulátorov.

V praktickej časti sú rozobrané tri prípady. British Airways slúži ako príklad veľkého incidentu s právnymi a reputačnými následkami; Ticketmaster ukazuje riziko skriptov tretích strán; Newegg je klasickým Magecart útokom na e-shop. Prípady sú porovnané podľa spôsobu kompromitácie, typu zasiahnutých údajov, úlohy tretích strán, času odhalenia a hlavných poučení. Kapitola o ochranných opatreniach nadväzuje na požiadavky PCI DSS 6.4.3 a 11.6.1, ktoré od prevádzkovateľov vyžadujú autorizáciu skriptov na platobných stránkach, kontrolu ich integrity a monitorovanie neoprávnených zmien [11].

1.3 Metodika a použité zdroje

Práca vychádza z verejne dostupných odborných a oficiálnych zdrojov. Pri definovaní web skimmingu sú použité zdroje FBI, CISA a Europolu, pretože opisujú e-skimming z pohľadu kybernetickej kriminality, prevencie a vyšetrovania. Europol pri medzinárodnej akcii identifikoval stovky kompromitovaných online obchodníkov, čo ilustruje praktický rozsah problému [1–3, 6].

Technická časť sa opiera o materiály OWASP (najmä riziká JavaScriptu tretích strán a Top 10 Client-Side Security Risks) a PCI Security Standards Council (bezpečnosť platobných stránok a prevencia e-skimmingu). Pri prípadových štúdiách sú prednostne použité oficiálne alebo dôveryhodné analytické zdroje: pre British Airways materiály

ICO, pre Ticketmaster dokument publikovaný cez European Data Protection Board a pre Newegg technická analýza spoločnosti Volexity [4, 7–12].

Metodika má analytický a komparatívny charakter: najskôr je vysvetlený mechanizmus útoku, potom sú rozobrané prípady (spôsob útoku, ohrozené údaje, úloha tretích strán, následky) a nakoniec sú porovnané a zhrnuté do poučení pre prevádzkovateľov e-shopov a online služieb.

2 Definícia web skimmingu

2.1 Pojem web skimming a základná definícia

Web skimming je forma počítačovej kriminality zameraná na krádež platobných a osobných údajov pri online platbách. V odbornej literatúre sa používajú aj označenia e-skimming, digital skimming, online skimming, formjacking alebo Magecart útok. Tieto pojmy nie sú vždy úplne synonymné, ale opisujú podobný princíp: útočník vloží alebo upraví škodlivý kód na webovej stránke (najčastejšie na platobnej alebo objednávkovej) a tento kód zachytáva údaje zadávané používateľom. Europol definuje digital skimming ako krádež informácií o platobnej karte alebo platobných údajov zákazníkov online obchodu [2].

CISA opisuje e-skimming ako vkladanie skimmingového kódu na platobné stránky e-commerce webov s cieľom zachytiť údaje z platobných kariet a osobne identifikovateľné informácie. FBI dopĺňa, že prístup k webu možno získať cez phishing voči zamestnancom alebo cez zraniteľného dodávateľa tretej strany. Z týchto definícií vyplýva, že podstatou web skimmingu nie je presmerovanie používateľa na falošnú stránku, ale zneužitie legitímnej stránky alebo legitímne vyzerajúceho platobného procesu [1, 3].

Z technického hľadiska ide najčastejšie o škodlivý JavaScript spustený v prehliadači zákazníka, ktorý sleduje formulár a kopíruje zadávané údaje. PCI Security Standards Council opisuje online skimming ako útok, pri ktorom je e-commerce stránka infikovaná škodlivým kódom (často nazývaným JavaScript sniffer), ktorý počas transakcie odcudzí platobné údaje bez vedomia obchodníka aj zákazníka [11].

S web skimmingom úzko súvisí pojem formjacking – označuje útok, pri ktorom JavaScript zachytáva údaje z formulárov na objednávkových alebo platobných stránkach, pričom sa používajú aj názvy Magecart alebo JavaScript skimming [13]. Pojem Magecart sa používa odlišne: neoznačuje konkrétny program, ale viacero kyberzločineckých skupín a kampaní, ktoré nasadzujú digitálne skimmery na kompromitované e-shopy a sú spájané s incidentmi British Airways, Ticketmaster a Newegg [14]. V tejto práci sa ako hlavný pojem používa web skimming, pretože najlepšie vystihuje podstatu útoku – digitálne zachytávanie údajov z platobného procesu na webovej stránke.

2.2 Odlišnosť od príbuzných foriem útokov

Pri phishingu sa útočník snaží presvedčiť používateľa, aby otvoril falošnú stránku a sám zadal údaje. Pri web skimmingu zákazník navštevuje skutočnú stránku legitímneho obchodníka – problémom nie je falošná doména, ale škodlivý kód vložený do legitímnej platobnej stránky alebo do skriptu, ktorý sa na nej načítava [1, 3].

Rozdiel je aj oproti úniku databázy. Pri ňom útočník získava údaje uložené na serveri (účty, e-mail, heslá). Pri web skimmingu sa údaje zachytávajú priamo v okamihu zadávania do formulára, ešte predtým, než ich spracuje platobná brána alebo server obchodníka. Práve toto zachytávanie počas checkout procesu je jedným zo základných znakov e-skimmingu [1, 11].

Web skimming sa odohráva na strane klienta, teda v prehliadači používateľa. Tradičné bezpečnostné opatrenia sa sústreďujú na server, databázu a administráciu, no problémom môže byť práve JavaScript spustený na platobnej stránke – či už od prevádzkovateľa, alebo od tretej strany (analytika, reklamný systém, chatbot, knižnica). OWASP zdôrazňuje, že jedným z najväčších rizík pri JavaScripte tretích strán je kompromitácia servera tretej strany a vloženie škodlivého kódu do pôvodného skriptu, ktorý sa následne načíta aj na platobnej stránke [4, 12].

Web skimming preto nie je problémom jedného súboru, ale celého reťazca komponentov. Prevádzkovateľ môže mať vlastnú aplikáciu zabezpečení, no ak na platobnej stránke beží kompromitovaný externý skript, riziko zostáva vysoké. Na rozdiel od ransomvéru, DDoS alebo defacementu navyše nenaruša dostupnosť: e-shop ďalej funguje a útok býva odhalený až nepriamo cez podvodné transakcie, monitoring alebo upozornenie banky [1, 4, 11, 12].

2.3 Typické znaky a rizikové prostredie

Typickým cieľom sú stránky, kde zákazníci zadávajú platobné alebo osobné údaje – e-shopy, cestovné portály, rezervačné systémy, stránky na predaj vstupeniek. Pre útočníkov sú atraktívne tým, že jedna kompromitovaná platobná stránka môže zhromažďovať údaje od veľkého počtu zákazníkov [2].

Typickým znakom je spojenie legitímneho prostredia a škodlivej funkcionality. Stránka môže byť dôveryhodná, používať HTTPS a patriť známej firme, no HTTPS chráni iba prenos medzi prehliadačom a serverom – ak je škodlivý kód súčasťou stránky, môže údaje zachytiť ešte pred ich odoslaním [1, 11].

Rizikom sú najmä stránky s množstvom externých skriptov a doplnkov (analytika, reklama, live chat, marketingové nástroje, pluginy, knižnice z cudzích serverov). Každý takýto prvok rozširuje plochu útoku. OWASP Top 10 Client-Side Security Risks upozorňuje na riziká úniku citlivých údajov, nedostatočnej kontroly tretích strán a zraniteľných alebo zastaraných komponentov [12]. Riziko rastie, keď prevádzkovateľ nemá prehľad o spúšťaných skriptoch – pri menších e-shopoch býva problémom zastaraná platforma, neaktualizované pluginy či slabé administrátorské heslá; pri väčších firmách komplikovaný dodávateľský reťazec, cez ktorý sa útočník môže dostať podľa FBI aj cez zraniteľného dodávateľa [3].

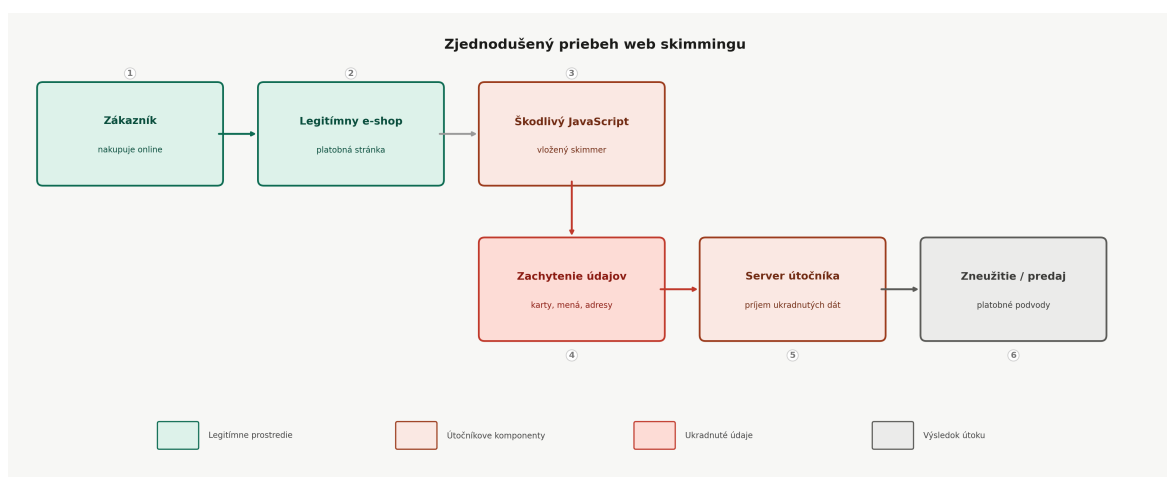
Z pohľadu kriminality majú ukradnuté údaje priamu finančnú hodnotu – môžu byť použité na neoprávnené platby, predané ďalším osobám alebo kombinované s inými osobnými údajmi. Web skimming je preto vhodné chápať ako finančne motivovanú kybernetickú kriminalitu, nie iba ako technickú zraniteľnosť. Súvisiacim bezpečnostným pojmom je integrita skriptov: mechanizmus Subresource Integrity umožňuje prehliadaču overiť, či načítaný externý zdroj zodpovedá očakávanému hashu, a ak sa obsah zmení, prehliadač ho nemusí načítať [1, 2, 5, 11].

3 Technický princíp útoku

3.1 Základný priebeh web skimmingu

Technický princíp web skimmingu spočíva v tom, že sa škodlivý kód dostane na stránku, na ktorej používateľ zadáva platobné alebo osobné údaje (najčastejšie objednávkový formulár alebo checkout). Kód pracuje priamo v prehliadači zákazníka, sleduje formulár a snaží sa údaje odoslať mimo prostredia obchodníka. CISA opisuje e-skimming ako útok, pri ktorom útočníci vkladajú skimmingový kód na platobné stránky e-commerce webov s cieľom získať údaje z platobných kariet a osobne identifikovateľné informácie [1].

Útok sa dá rozdeliť na fázy: útočník získa možnosť ovplyvniť obsah stránky alebo niektorý zo skriptov, vloží škodlivý JavaScript (alebo upraví existujúci), kód sa spustí pri otvorení stránky a po vyplnení formulára prečíta a odošle údaje na infraštruktúru útočníka. FBI uvádza, že prístup k webu môže vzniknúť cez phishing voči zamestnancom alebo cez zraniteľného dodávateľa tretej strany s prístupom do systémov firmy [3]. Krádež sa pritom nemusí odohrať až v databáze: údaje sa kopírujú už počas vyplňania formulára, takže útok je nebezpečný aj vtedy, keď samotná databáza ani platobná brána neboli prelomené [1, 11].



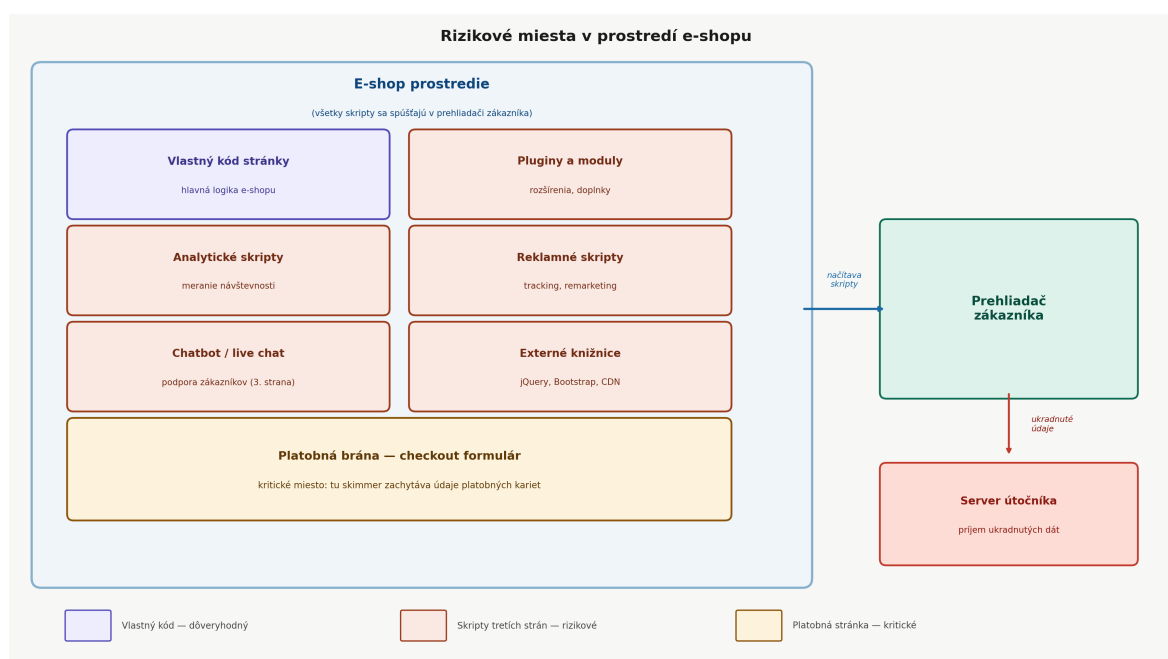
Obr. 1: Zjednodušený priebeh web skimmingu.

Web skimming je zároveň útokom na dôveru. Zákazník vidí známu doménu, bežný dizajn a funkčný platobný proces, no na stránke môže paralelne bežať aj ďalší kód, ktorý kópiu údajov odošle mimo prostredia obchodníka. PCI Security Standards Council pri online skimmingu zdôrazňuje, že platobné údaje môžu byť odcudzené počas transakcie bez vedomia obchodníka aj zákazníka [11].

3.2 Vstupné body a kompromitácia stránky

Prvou fázou je získanie prístupu k webu alebo k prvku, ktorý sa naň načítava. Útočník nemusí prelomiť hlavný server: stačia slabé prihlasovacie údaje do administrácie, zraniteľný plugin, zastaraná e-commerce platforma, nesprávne nastavené oprávnenia alebo kompromitovaný účet správcu. FBI medzi cestami uvádza aj phishing a zneužitie zraniteľného dodávateľa tretej strany [3].

Významným vstupným bodom sú skripty tretích strán – analytika, reklamné systémy, chatboty, marketingové nástroje, platobné doplnky či knižnice z cudzích serverov. Ak je kompromitovaný takýto externý prvok, útočník nemusí meniť hlavný kód e-shopu; stačí, že sa zmenený skript načíta na stránke zákazníka. OWASP upozorňuje, že jedným z najväčších rizík pri JavaScripte tretích strán je práve kompromitácia servera tretej strany a vloženie škodlivého JavaScriptu do pôvodného skriptu [4]. Čím viac externých skriptov beží na platobnej stránke, tým väčšiu plochu musí prevádzkovateľ kontrolovať. OWASP Top 10 Client-Side Security Risks preto zdôrazňuje aj nedostatočnú kontrolu tretích strán a zraniteľné či zastarané komponenty [12].



Obr. 2: Rizikové miesta v prostredí e-shopu pri načítavaní klientských skriptov.

Kompromitácia nemusí znamenať prevzatie celého systému – môže ísť o nenápadnú zmenu v jednom súbore, doplnenie krátkeho skriptu alebo úpravu externého zdroja. Ak útočník navyše obmedzí spustenie kódu iba na stránky s platbou, útok môže byť pre bežného používateľa prakticky neviditeľný [1, 11].

3.3 Zachytávanie údajov v prehliadači používateľa

Po vložení škodlivého JavaScriptu nasleduje zachytávanie údajov: kód sa spustí v prehliadači spolu s ostatnými časťami stránky a po vyplnení formulára pristupuje k hodnotám polí – meno, priezvisko, e-mail, adresa, telefón, číslo karty, dátum expirácie, bezpečnostný kód. CISA pri e-skimmingu zdôrazňuje práve zachytávanie údajov z platobných kariet a osobne identifikovateľných informácií z checkout formulárov [1].

Proces sa odohráva na strane klienta. JavaScript je bežnou súčasťou webov a používa sa na validáciu, interaktivitu, výpočty cien či komunikáciu s API; rovnaké možnosti však môžu byť zneužitú na sledovanie polí. Riziko vzniká vtedy, keď sa na citlivej stránke spustí kód, ktorému prevádzkovateľ nerozumie a nedokáže overiť jeho integritu [4, 12]. Útoky sú navyše navrhnuté tak, aby legitímny proces nenarušili: platba prebehne, objednávka sa vytvorí a kópia údajov sa zároveň odošle útočníkovi – práve preto môžu byť údaje zachytené ešte pred ich odoslaním platobnej bráne. HTTPS chráni iba prenos medzi prehliadačom a serverom, nie dôveryhodnosť kódu na samotnej stránke [1, 5, 11].

3.4 Odosielanie údajov a maskovanie útoku

Po zachytení sa údaje odosielať na externú infraštruktúru, ktorá nepatrí obchodníkovi ani platobnej bráne. Na stránke s množstvom externých prvkov sa takýto prenos môže stratiť medzi bežnou komunikáciou s analytikou alebo reklamou. Útočníci aktivitu skrývajú: nenápadné názvy súborov, domény pripomínajúce legitímne knižnice, analytické služby alebo CDN, minifikovaný či obfuskovaný JavaScript a spustenie kódu iba na konkrétnych stránkach. Ak správca nekontroluje zoznam načítavaných skriptov a cieľových domén, nemusí si všimnúť, že platobná stránka komunikuje s podozrivým serverom [1, 4, 11, 12].

Jednou z technických obran je Subresource Integrity, ktorá umožňuje prehliadaču overiť, či externý súbor zodpovedá očakávanému hashu, a ak sa zmenil, neprijat' ho [5]. SRI však nestačí, ak prevádzkovateľ nemá prehľad o skriptoch na platobnej stránke. PCI Security Standards Council preto zdôrazňuje autorizáciu skriptov, kontrolu ich integrity a monitorovanie zmien – útok totiž stojí na tom, že sa do citlivej stránky dostane kód, ktorý tam nemá byť alebo ktorého obsah sa zmenil [11].

3.5 Prečo je detekcia web skimmingu náročná

Detekcia je náročná, lebo útok nespôsobuje viditeľnú poruchu webu – objednávky prechádzajú a obchodník ďalej prijíma platby. Problém sa prejaví až nepriamo: zvýšeným počtom podvodných transakcií, upozornením banky, bezpečnostným skenovaním alebo analýzou sieťovej komunikácie [1, 11]. Komplikuje to aj dynamická povaha webov: obsah

sa mení podľa zariadenia, krajiny, účtu či kroku v nákupe a škodlivý kód sa môže spúšťať len na checkout stránke alebo pri konkrétnom poli [12].

Detekciu sťažuje aj veľký počet legitímnych skriptov a fakt, že útok prebieha na strane klienta – serverové logy nemusia obsahovať dôkaz o odoslaní údajov tretej strane, lebo to prebieha priamo z prehliadača. Ochrana preto musí kombinovať serverovú bezpečnosť, kontrolu klientského kódu, monitoring externých zdrojov a pravidelné testovanie platobného procesu [4, 11, 12].

Technický princíp teda spočíva v zneužití klientského prostredia a dôvery používateľa: útočník nemusí prelomiť platobnú bránu ani databázu – stačí dostať škodlivý JavaScript na miesto, kde používateľ zadáva citlivé údaje. Web skimming si preto vyžaduje opatrenia zamerané nielen na servery, ale aj na integritu platobných stránok a kontrolu skriptov [1, 4, 11].

4 Kriminálna podstata a dopady útoku

4.1 Web skimming ako forma finančne motivovanej kriminality

Web skimming nie je iba technický problém – v jadre ide o finančne motivovanú kriminalitu, pri ktorej útočník nezasahuje do webu bezdôvodne, ale preto, aby získal údaje použiteľné na ďalší zisk. Hlavnou hodnotou nie je zmena vzhladu, poškodenie databázy či výpadok služby, ale platobné a osobné údaje zákazníkov, ktoré možno zneužiť pri podvodných platbách, predat alebo použiť v ďalších útokoch [1, 2].

Útok sa odohráva počas legitímne vyzerajúceho nákupu: zákazník navštíví skutočnú stránku obchodníka, vyplní formulár, no škodlivý skript údaje zároveň skopíruje a odošle mimo prostredia obchodníka. Na rozdiel od phishingu obeť nemusí byť presviedčaná navštíviť falošnú stránku, takže často nevie, kde k úniku došlo; problém sa prejaví až pri podozrivej transakcii, upozornení banky alebo oznámení incidentu [1, 3, 11].

Z pohľadu kriminality sa spája viacero krokov: neoprávnené ovplyvnenie stránky, skriptu alebo dodávateľského reťazca, neoprávnené získanie platobných a osobných údajov a ich následné zneužitie, predaj alebo odovzdanie ďalším aktérom. Práve táto postupnosť odlišuje web skimming od samotnej zraniteľnosti – jej zneužitie na získanie cudzieho majetkového prospechu už patrí do trestnej a finančnej kriminality [1, 2, 15]. Útok má zároveň systematický charakter: pojem Magecart neoznačuje jeden program, ale širší okruh skupín, kampaní a techník, čo svedčí o opakovanom kriminálnom modeli zameranom na online platby [14].

4.2 Dopady na zákazníkov a zneužitie ukradnutých údajov

Najpriamejšou obeťou je zákazník. Ohrozené môžu byť meno, e-mail, telefón, fakturačná či doručovacia adresa a údaje z platobnej karty. Pri e-skimmingu nejde iba o krádež čísla karty, ale aj o získavanie osobne identifikovateľných informácií z checkout formulárov [1]. Pre platby bez fyzickej karty sú cenné najmä číslo karty, dátum expirácie, meno držiteľa a bezpečnostný kód; v kombinácii s adresnými údajmi vzniká priestor na ďalšie zneužitie [2].

Dopad nemusí končiť pri samotnej podvodnej transakcii. Aj keď banka platbu zablokuje, obeť rieši výmenu karty, kontrolu účtu a neistotu, ktoré ďalšie údaje boli odcudzené. Osobné údaje z jedného incidentu sa navyše kombinujú s údajmi z iných únikov a vytvárajú priestor pre cielenejšie sociálne inžinierstvo či pokusy o prevzatie účtov [16]. Problém zhoršuje oneskorené odhalenie – škodlivý kód môže byť aktívny

dlhšie, a Europol pri akcii proti digital skimmingu identifikoval stovky kompromitovaných obchodníkov, čo svedčí o rozsahu javu [6].

Bežné signály opatrnosti pritom nestačia: doména, HTTPS ani známe meno obchodníka nezaručujú, že stránka neobsahuje škodlivý skript – zlyhanie býva na strane webovej služby alebo dodávateľského reťazca [4, 11].

4.3 Dopady na prevádzkovateľov e-shopov a online služieb

Prevádzkovateľ je zasiahnutý viacerými spôsobmi. Prvým je strata dôvery: ak sa stránka stane nástrojom krádeže údajov, reputačná škoda môže byť vážna a zákazníci môžu službu prestať používať. Druhým sú náklady na riešenie incidentu – identifikácia kompromitácie, odstránenie kódu, forenzná analýza, komunikácia so zákazníkmi a platobnými partnermi, prípadne zapojenie bánk, kartových spoločností, právnikov či dozorných orgánov [11, 16].

Tretím dopadom je právna a regulačná zodpovednosť. GDPR vyžaduje primerané technické a organizačné opatrenia a pri incidente sa skúma, či boli vzhľadom na riziko dostatočné. Pri web skimmingu nestačí tvrdiť, že údaje ukradol externý útočník; podstatné je aj to, ako prevádzkovateľ chránil platobnú stránku, externé skripty a prostredie, v ktorom zákazník údaje zadával [11, 16].

Vážnosť následkov dokumentuje British Airways: ICO pôvodne oznámilo zámer pokuty 183,39 milióna libier, konečná pokuta dosiahla 20 miliónov libier a incident sa týkal viac ako 400 000 zákazníkov [7, 8]. Ticketmaster zase ukazuje, že zodpovednosť sa nekončí pri vlastnom kóde – ak firma na platobnej stránke používa externé skripty, chatboty či analytiku, musí riešiť aj ich bezpečnosť a primeranosť [4, 9]. Ak je na platobnej stránke veľa nekontrolovaných externých skriptov, rastie riziko ich zneužitia – preto PCI Security Standards Council zdôrazňuje autorizáciu skriptov, kontrolu integrity a monitorovanie zmien [11].

4.4 Právny a regulačný rozmer incidentu

Pri web skimmingu treba rozlišovať trestnoprávny pohľad na páchatela a regulačný pohľad na povinnosti prevádzkovateľa [15, 16]. Zo slovenského trestnoprávneho pohľadu môže ísť najmä o neoprávnený prístup alebo zásah do počítačového systému, manipuláciu s údajmi, podvodné konanie alebo neoprávnené nakladanie s platobným prostriedkom. Presná kvalifikácia závisí od konkrétnych okolností – ako sa páchatel dostal k webu, čo upravil, aké údaje získal, aká škoda vznikla a ako boli údaje použité [15]. Ak útočník

bez oprávnenia získa prístup, vloží škodlivý kód a zhromažďuje cudzie platobné údaje, incident sa presúva z technickej roviny do oblasti finančnej kriminality [1, 2].

Regulačný rozmer sa týka najmä ochrany osobných údajov. GDPR v článku 32 vyžaduje primeranú bezpečnosť spracúvania s ohľadom na stav techniky, povahu, rozsah, kontext a riziká pre práva fyzických osôb. Pri incidente sa skúma, či prevádzkovateľ prijal opatrenia primerané riziku – pri web skimmingu najmä kontrolu klientskeho kódu, skriptov tretích strán a zmien na platobnej stránke [11, 16]. Ak incident predstavuje riziko pre práva osôb, prevádzkovateľ ho má oznámiť dozornému orgánu spravidla do 72 hodín a pri vysokom riziku informovať aj zákazníkov [16].

Známe prípady ukazujú, že dozorné orgány neposudzujú iba samotný fakt útoku, ale aj zavedené opatrenia, rýchlosť odhalenia a reakciu. Pri British Airways aj Ticketmaster vidieť prepojenie technického incidentu, ochrany osobných údajov, reputačných následkov a regulačnej zodpovednosti [7–9]. Web skimming je preto závažným javom, ktorý zasahuje technickú bezpečnosť, ochranu osobných údajov, finančnú bezpečnosť zákazníkov aj právnu zodpovednosť online služieb [11, 15, 16].

5 Prípadová štúdia: British Airways

5.1 Charakteristika incidentu

Incident British Airways patrí medzi najznámejšie prípady web skimmingu, pretože spojil technický útok na online službu s rozsiahlymi následkami v ochrane osobných údajov. Pri kúpe letenky zákazník zadáva kontaktné, cestovné a platobné údaje – kombináciu informácií zneužitelnú pri finančných podvodoch aj pri ďalšej práci s identitou obete.

ICO v roku 2019 oznámil zámer uložiť British Airways pokutu 183,39 milióna libier za porušenie GDPR. Podľa oznámenia boli zákaznícke údaje počas útoku presmerované na podvodnú stránku; spoločnosť incident oznámila v septembri 2018 a pôvodné oznámenie uvádzalo až 500 000 dotknutých zákazníkov [7]. Konečné rozhodnutie znížilo pokutu na 20 miliónov libier; podľa zhrnutia útok prebiehal od 22. júna do 5. septembra 2018 a útočník získal prístup k údajom platobných kariet a osobným údajom približne 429 000 zákazníkov, pričom incident sa týkal viac ako 400 000 osôb [8, 17].

Význam prípadu nespočíva iba v technike útoku. Útok vykonal externý páchatel, no posudzovalo sa aj to, či mala British Airways primerané technické a organizačné opatrenia. Web skimming tak nie je len problémom škodlivého kódu, ale aj riadenia bezpečnosti, monitoringu a ochrany osobných údajov.

5.2 Technická a kriminálna stránka prípadu

Prípad zodpovedá základnej logike web skimmingu: zákazníci používali legítimnú službu a údaje zadávali v rámci bežného rezervačného alebo platobného procesu, ale časť údajov bola počas útoku zachytávaná a smerovaná mimo prostredia spoločnosti. ICO uviedlo, že incident zahŕňal presmerovanie používateľskej prevádzky z webu British Airways na podvodnú stránku, kde útočníci zhromažďovali údaje [7]. Mechanizmus dobre vystihuje rozdiel oproti phishingu: zákazník nemusel vyhľadať falošnú stránku – riziko vzniklo v rámci služby, ktorú oprávnené považoval za dôveryhodnú.

Podľa právneho zhrnutia útočník najskôr využil prihlasovacie údaje spojené s externým dodávateľom Swissport a z obmedzeného prostredia sa dostal do širšej siete British Airways. Údaje sa získavali viacerými spôsobmi vrátane nešifrovaných logov a presmerovania platobných údajov z webu na infraštruktúru útočníka [17]. Pre túto prácu je dôležitá najmä druhá časť, lebo zodpovedá útoku na platobný proces a klientsku časť služby. Kriminálna podstata spočíva v neoprávnenom získavaní osobných a platobných údajov, ktoré majú priamu ekonomickú hodnotu [1, 2]. Prípad je často uvádzaný v súvislosti s pojmom Magecart – Fortinet ho zaraďuje medzi známe príklady tohto typu digitálneho skimmingu [14].

Dôležité je aj oneskorené odhalenie. Škodlivá aktivita bola aktívna viac ako dva mesiace a spoločnosť bola na podozrivý prenos upozornená tretou stranou [17]. To potvrdzuje, že web skimming neútočí na dostupnosť služby, ale potichu odčerpáva údaje z procesu, ktorý používateľ považuje za legitímny.

5.3 Následky a význam prípadu

Najviditeľnejším následkom bola sankcia ICO. Pôvodný zámer 183,39 milióna libier vyvolal výraznú pozornosť, pretože išlo o jeden z prvých veľkých prípadov po zavedení GDPR [7]; konečná pokuta 20 miliónov libier bola síce nižšia, ale stále predstavovala jasný signál, že nedostatočná ochrana zákazníckych údajov má vážne právne a finančné dôsledky [8]. K tomu sa pripája reputačný dopad – pri kompromitácii údajov pri bežnej rezervácii sa narúša dôvera v schopnosť veľkej organizácie chrániť celý digitálny proces, takže firma rieši aj komunikáciu so zákazníkmi, partnermi, regulátorom a verejnosťou.

Prípad ukazuje praktický význam povinnosti prijať primerané technické a organizačné opatrenia: nestačí spätne konštatovať, že útok vykonal externý páchateľ – organizácia musí vedieť kontrolovať systémy, znižovať riziko zneužitia prístupov a detegovať podozrivé zmeny. ICO považovalo za významné, že dostupné bezpečnostné opatrenia mohli útok zastaviť alebo aspoň obmedziť jeho dopad [17]. British Airways je zároveň dôkazom, že veľké spoločnosti nie sú automaticky chránené – sú atraktívnym cieľom práve pre objem transakcií a údajov, ktoré spracúvajú. V porovnaní s ďalšími prípadmi British Airways najvýraznejšie ukazuje právne a regulačné následky web skimmingu, kým Ticketmaster zvyrazňuje riziko tretej strany a Newegg klasický Magecart scenár.

5.4 Zhrnutie prípadu British Airways

Tabuľka 1: Zhrnutie prípadu British Airways

Kritérium	British Airways
Rok incidentu	2018
Typ organizácie	Letecká spoločnosť a online rezervačná služba
Typ útoku	Web skimming a presmerovanie zákazníckych údajov mimo legitímneho prostredia služby
Ohrozené údaje	Osobné údaje a údaje platobných kariet zákazníkov
Počet dotknutých zákazníkov	Viac ako 400 000 podľa konečného rozhodnutia; približne 500 000 podľa pôvodného oznámenia ICO
Regulačný následok	Pôvodne oznámený zámer pokuty 183,39 milióna libier; konečná pokuta 20 miliónov libier
Hlavné poučenie	Potreba monitorovať webovú a sieťovú infraštruktúru, chrániť platobný proces a včas odhaľovať neoprávnené zmeny alebo podozrivý prenos údajov

6 Prípadová štúdia: Ticketmaster

6.1 Charakteristika incidentu

Prípad Ticketmaster UK Limited patrí medzi najvýznamnejšie príklady web skimmingu v prostredí služieb tretích strán. Pri online predaji vstupeniek zákazníci zadávajú osobné a platobné údaje, takže ide o prostredie s priamou finančnou hodnotou. Osobitosť tohto prípadu spočívala v tom, že riziko nesúviselo len s vlastnou stránkou Ticketmasteru, ale aj s chatbotom tretej strany nasadeným v online prostredí vrátane platobnej stránky [9].

Podľa rozhodnutia ICO sa posudzovaný incident týkal osobných údajov spracúvaných od 25. mája do 23. júna 2018, pričom širšie porušenie ochrany osobných údajov trvalo už od februára 2018. Ako potenciálne dotknutých bolo informovaných približne 9,4 milióna osôb v EHP, z toho približne 1,5 milióna zo Spojeného kráľovstva. Škodlivý kód spojený s chatbotom mohol zachytávať údaje vrátane mena, adresy, e-mailu, čísla platobnej karty, bezpečnostného kódu a prihlasovacích údajov do služby [9].

Incident neostal v rovine potenciálneho ohrozenia. Barclays Bank informovala o približne 60 000 kompromitovaných kartách a Monzo Bank vymenila približne 6 000 kariet; Ticketmaster prijal okolo 997 sťažností týkajúcich sa finančnej straty alebo emocionálnej ujmy [9]. Web skimming tak môže mať praktický dopad nielen na prevádzkovateľa a zákazníkov, ale aj na banky a platobné inštitúcie.

6.2 Technická a kriminálna stránka prípadu

Technickú podstatu tvoril chatbot spoločnosti Inbenta, ktorý slúžil ako zákaznícke rozhranie a na niektorých stránkach bol aktívny aj bez priamej interakcie. Škodlivý kód spojený s týmto komponentom mohol zachytávať údaje zadávané používateľmi v prostredí, kde bol nasadený [9]. Pre web skimming je to kľúčové: nebezpečný nemusí byť iba kód prevádzkovateľa, ale aj externý prvok spustený v prehliadači zákazníka. Útok navyše nemusí začínať prelomením hlavného servera – riziko vzniká cez komponent tretej strany v používateľskom rozhraní, ktorý sa stáva súčasťou bezpečnostného rizika celého procesu [4, 9].

Z kriminálneho hľadiska je podstatné, že útočník mohol získať údaje zadávané v legitímnom nákupnom procese – zákazník bol na skutočnej stránke predajcu, no kompromitovaný komponent zachytával údaje bez toho, aby si to všimol [1, 9]. ICO Ticketmasteru vytýkalo nedostatočné posúdenie rizík chatbota na platobnej stránke, nedostatočné bezpečnostné opatrenia a oneskorené určenie zdroja podozrivej aktivity [9]. Incident teda nie je iba zlyhaním externého dodávateľa – prevádzkovateľ musel vedieť, aký kód sa na platobnej stránke spúšťa. Kauza nadväzuje na všeobecné riziká JavaScriptu tretích strán a požiadavky PCI Security Standards Council na autorizáciu skriptov, kontrolu integrity a monitorovanie neoprávnených zmien [4, 11].

6.3 Následky a význam prípadu

ICO uložilo Ticketmaster UK Limited pokutu 1,25 milióna libier. Konštatovalo porušenie článku 5 ods. 1 písm. f) GDPR a článku 32 GDPR – princípu integrity a dôvernosti a povinnosti prijať primerané technické a organizačné opatrenia [9]. Prípád ukazuje, že zodpovednosť prevádzkovateľa sa vzťahuje aj na riziká z externých služieb: Ticketmaster nemusel byť autorom škodlivého kódu, no externý komponent bol súčasťou prostredia, kde zákazníci zadávali údaje, takže problém nemožno presunúť iba na dodávateľa [11].

Incident mal dopad aj na bankový sektor – vyhodnotenie podozrivých transakcií, blokovanie a výmena kariet sú reťazovým dopadom web skimmingu na viacero subjektov naraz [9]. V porovnaní s British Airways je Ticketmaster odlišný dôrazom na externý prvok v platobnom procese: British Airways ukazuje právny a reputačný dopad veľkej značky, Ticketmaster nebezpečenstvo skriptu tretej strany na citlivej stránke [7, 8]. Hlavným poučením je, že každý externý skript na platobnej stránke rozširuje plochu útoku a musí byť hodnotený, kontrolovaný a monitorovaný [4].

6.4 Zhrnutie prípadu Ticketmaster

Tabuľka 2: Základné údaje o prípade Ticketmaster

Kritérium	Ticketmaster UK Limited
Rok incidentu	2018
Typ organizácie	Online predaj vstupeniek
Typ útoku	Web skimming cez komponent tretej strany
Rizikový prvok	Chatbot tretej strany nasadený aj v online platobnom prostredí
Potenciálne dotknuté osoby	Približne 9,4 milióna osôb v EHP, z toho približne 1,5 milióna v Spojenom kráľovstve
Dopad na platobné karty	Približne 60 000 kompromitovaných kariet Barclays a približne 6 000 vymenených kariet Monzo
Regulačný následok	Pokuta 1,25 milióna libier od ICO
Hlavné poučenie	Externé skripty a služby tretích strán na platobnej stránke musia byť hodnotené, kontrolované a monitorované

7 Prípadová štúdia: Newegg a Magecart

7.1 Charakteristika incidentu

Prípad Newegg patrí medzi známe príklady web skimmingu vo veľkom e-commerce prostredí. Newegg je internetový predajca elektroniky a počítačového hardvéru, kde zákazníci počas nákupu zadávajú platobné údaje priamo v objednávkovom procese. V porovnaní s British Airways a Ticketmaster je Newegg vhodný najmä ako ukážka klasického Magecart scenára – vloženia škodlivého JavaScriptu do checkout procesu e-shopu [10, 14].

Podľa analýzy Volexity (v spolupráci s RiskIQ) bol útok zameraný na e-commerce operácie Newegg a pripísaný aktérom Magecart. Volexity overila prítomnosť škodlivého JavaScriptu na stránke `secure.newegg.com`, konkrétne v checkout procese na stránke s fakturačnými údajmi. Kód získaval údaje z formulára a odosielať ich na doménu kontrolovanú útočníkmi [10].

Útočníci použili doménu `neweggstats.com`, ktorá pripomínala legitímne prostredie spoločnosti Newegg a mohla pôsobiť ako analytická služba. Volexity uviedla, že doména bola zaregistrovaná 13. augusta 2018 a škodlivý kód bol odstránený 18. septembra 2018 – útok teda mohol byť aktívny približne mesiac. Stránka pritom pre zákazníka fungovala

bežne a používatelia mohli dokončiť objednávku, no skript paralelne kopíroval údaje a odosiela ich mimo prostredia obchodníka [10].

7.2 Technická a kriminálna stránka prípadu

Prípad dobre ilustruje princíp web skimmingu: zákazník nakupoval na legítimnej stránke Newegg a nachádzal sa v skutočnom checkout procese, no do tejto časti webu bol vložený škodlivý JavaScript schopný zachytávať údaje z platobného formulára [10]. Podľa Volexity bol kód pomerne malý a prispôsobený konkrétnej stránke – aktivoval sa pri interakcii s platobným tlačidlom, čítal údaje z formulára a odosiela ich na infraštruktúru útočníka. Bol podobný kódu pri British Airways, ale ešte viac minimalizovaný a prispôsobený cieľovej stránke, čo svedčí o tom, že aktéri Magecart skripty cielene upravovali [10].

Z pohľadu kriminality bol cieľ jednoznačný – získať platobné údaje počas nákupu. Web skimming je tu finančne motivovaná kriminalita, v ktorej je škodlivý kód iba nástrojom na získanie údajov s ekonomickou hodnotou [1, 2]. Charakteristické bolo aj maskovanie: doména neweggstats.com pôsobila ako bežná súčasť prevádzky a v prostredí plnom analytických a externých služieb mohla byť ľahko prehliadnutá [4, 12]. Prípad zároveň ukazuje, že HTTPS na ochranu nestačí – zachytené údaje boli odosielané cez SSL/TLS na doménu útočníkov; šifrovaný prenos chráni iba pred odpočúvaním po ceste, nie pred nedôveryhodným cieľom komunikácie [5, 10, 11].

7.3 Následky a význam prípadu

Newegg ukazuje typický útok na samotný checkout proces. Pri British Airways bol výrazný právny dopad, pri Ticketmaster riziko služby tretej strany; Newegg priamo ilustruje technický model Magecart útoku v e-commerce – útočník nepotreboval narušiť dostupnosť, stačilo, aby sa kód spustil v správnom momente pri zadávaní údajov [10, 14]. Útočnická infraštruktúra bola pritom zámerne prispôbena kontextu cieľovej služby a kód optimalizovaný tak, aby zanechal čo najmenšiu stopu [10].

Hlavným poučením pre prevádzkovateľov je, že nestačí kontrolovať iba server a databázu – rovnako dôležité je sledovať klientský kód na platobnej stránke, externé domény, ktoré stránka kontaktuje, a prípadné neoprávnené zmeny skriptov. PCI Security Standards Council preto zdôrazňuje autorizáciu skriptov, kontrolu integrity a monitorovanie zmien [11]. Pre obranu z toho vyplýva, že nestačí hľadať známe vzory škodlivého kódu – treba sledovať aj zmeny správania platobnej stránky a komunikáciu s externými doménami.

7.4 Zhrnutie prípadu Newegg

Tabuľka 3: Základné údaje o prípade Newegg

Kritérium	Newegg
Rok incidentu	2018
Typ organizácie	E-commerce obchod s elektronikou a počítačovým hardvérom
Typ útoku	Magecart / web skimming
Cieľ útoku	Checkout proces a platobné údaje zákazníkov
Technický prvok	Škodlivý JavaScript v checkout procese na doméne secure.newegg.com
Útočná infraštruktúra	Doména neweggstats.com
Obdobie útoku	Približne august až september 2018
Hlavné poučenie	Nutnosť monitorovať klientský kód, externé domény a zmeny na platobných stránkach

8 Porovnanie prípadov

8.1 Spoločné znaky vybraných incidentov

British Airways, Ticketmaster a Newegg sú odlišné situácie, ale spája ich rovnaký mechanizmus: používateľ pracoval s legitímnou online službou a údaje zadával počas bežného nákupu. Nešlo o phishingový scenár s falošnou stránkou – riziko vzniklo priamo v prostredí služby, ktorej zákazník dôveroval [7, 9, 10]. Spoločná je aj finančná motivácia: útočníkom nešlo o znefunkčnenie služby, ale o údaje s ekonomickou hodnotou [14].

Ďalšou spoločnou črtou je nenápadnosť. Web skimming nespôsobuje výpadok – stránka funguje, objednávka prejde a útok sa odhalí až nepriamo cez podozrivé transakcie, upozornenie banky alebo regulátora. Najzreteľnejšie to vidieť pri British Airways a Newegg, kde incident nebol pre používateľa okamžite viditeľný [10, 11, 17]. Všetky tri prípady zároveň potvrdzujú význam kontroly klientského kódu: nestačí chrániť databázu, server či prenos – prevádzkovateľ musí vedieť, aký JavaScript sa spúšťa na platobnej stránke, odkiaľ pochádza a či sa nemení bez vedomia správcu [4, 9, 11].

8.2 Rozdiely medzi prípadmi

Každý prípad zvyrazňuje inú časť problému. British Airways je najvýraznejší pre právne, finančné a reputačné následky – pôvodne oznámený zámer vysokej pokuty a konečné rozhodnutie 20 miliónov libier ukazujú, že web skimming môže prerásť z technického narušenia do rozsiahleho prípadu ochrany osobných údajov a firemnej zodpovednosti [7, 8].

Ticketmaster je najdôležitejší z pohľadu rizika tretích strán: chatbot tretej strany nebol okrajovým prvkom, lebo sa nachádzal v prostredí so zadávaním citlivých údajov, takže prevádzkovateľ musí posudzovať aj bezpečnosť externých skriptov na platobnej stránke [9, 11]. Newegg je najčistejší technický príklad útoku Magecart – škodlivý JavaScript v checkout procese odosiela údaje na doménu neweggstats.com, zvolenú tak, aby pôsobila ako legitímne prostredie spoločnosti. Prípad ilustruje maskovanie infraštruktúry a význam monitorovania externých domén [10].

8.3 Komparatívna tabuľka

8.4 Vyhodnotenie a hlavné poučenia

Web skimming nie je jeden konkrétny postup, ale skupina útokov so spoločným cieľom a rôznym vstupným bodom, infraštruktúrou aj následkami. Vo všetkých prípadoch

Tabuľka 4: Porovnanie vybraných prípadov web skimmingu

Kritérium	British Airways	Ticketmaster	Newegg
Rok incidentu	2018	2018	2018
Typ organizácie	Letecká spoločnosť a online rezervačná služba	Online predaj vstupeniek	E-commerce obchod s elektronikou
Hlavný typ útoku	Web skimming a presmerovanie zákazníckych údajov	Web skimming cez komponent tretej strany	Magecart / web skimming v checkout procese
Hlavný rizikový prvok	Nedostatočne chránený online rezervačný a platobný proces	Chatbot tretej strany na platobnej stránke	Škodlivý JavaScript na doméne secure.newegg.com
Ohrozené údaje	Osobné a platobné údaje zákazníkov	Osobné a platobné údaje zákazníkov	Platobné údaje zákazníkov
Osobitná črta prípadu	Výrazný GDPR a reputačný dopad	Riziko služieb tretích strán	Technicky jasný Magecart scenár
Regulačný alebo verejný následok	Konečná pokuta 20 miliónov libier	Pokuta 1,25 milióna libier	Verejne známa technická analýza útoku
Hlavné poučenie	Potreba včasného odhalenia útoku a ochrany zákazníckych údajov	Externé skripty na platobnej stránke musia byť kontrolované	Checkout proces musí byť monitorovaný na úrovni klientského kódu aj komunikácie s externými doménami

útočníci využívajú to, že platobná stránka je dôveryhodným miestom, kde zákazník zadáva citlivé údaje [1, 4, 11].

Najdôležitejšie poučenie sa týka kontroly toho, čo sa na platobnej stránke reálne spúšťa: aj pri zabezpečenej databáze, šifrovanom prenose a legitímnej platobnej bráne môžu byť údaje odcudzené, ak na stránke beží neautorizovaný alebo kompromitovaný JavaScript – preto PCI Security Standards Council zdôrazňuje autorizáciu skriptov, kontrolu integrity a monitorovanie zmien [11]. Druhé poučenie sa týka tretích strán: Ticketmaster ukazuje, že externá služba v platobnom procese môže vytvoriť kritické riziko, takže každý takýto prvok musí byť odôvodnený, kontrolovaný a monitorovaný [4, 9, 12]. Tretie poučenie sa týka detekcie: British Airways aj Newegg dokazujú, že útok môže fungovať dlhší čas bez všimnutia, takže nestačí reagovať až po sťažnostiach – nutné je aktívne monitorovanie zmien na platobných stránkach, kontrola externých domén a testovanie klientského prostredia [10, 17].

Web skimming je teda vážna forma počítačovej kriminality práve preto, že spája technickú nenápadnosť s priamym finančným dopadom. Spoločne všetky tri prípady dokazujú, že ochrana platobných stránok musí zahŕňať nielen serverovú bezpečnosť, ale aj kontrolu klientského kódu, externých skriptov a celého dodávateľského reťazca webovej aplikácie [7–10, 14].

9 Možnosti prevencie a ochrany

9.1 Ochrana platobnej stránky a správa skriptov

Ochrana proti web skimmingu vychádza z toho, že útok prebieha priamo v prehliadači zákazníka, nie iba na serveri. Nestačí teda chrániť databázu, administráciu či platobný server – prevádzkovateľ musí mať prehľad aj o tom, aký JavaScript sa spúšťa na platobnej stránke, odkiaľ pochádza a či zodpovedá očakávanej verzii.

Dôležitým opatrením je obmedzenie počtu skriptov tam, kde zákazník zadáva platobné údaje. Stránka by nemala obsahovať zbytočné marketingové, reklamné, analytické či podporné prvky – každý externý skript je ďalším bodom dôvery a potenciálnym rizikom [4]. PCI Security Standards Council preto zdôrazňuje autorizáciu skriptov, kontrolu ich integrity a monitorovanie neoprávnených zmien – prevádzkovateľ musí vedieť, ktoré skripty sú povolené, prečo sú potrebné a či sa ich obsah nezmenil bez schválenia [11]. Prípád Ticketmaster ukázal, že aj prvok pôsobiaci ako pomocná služba (chatbot) sa stáva vážnym rizikom, ak je vložený tam, kde sa zadávajú platobné údaje [9].

9.2 Technické opatrenia

Content Security Policy (CSP) umožňuje určiť, z ktorých zdrojov môže stránka načítavať skripty, štýly a obrázky a obmedziť aj komunikáciu s neznámymi doménami. Pri web skimmingu je to dôležité, lebo škodlivý kód sa snaží odoslať údaje na server útočníka – CSP nie je samostatným riešením, ale znižuje priestor pre neoprávnenú komunikáciu [4, 12]. Subresource Integrity (SRI) umožňuje prehliadaču overiť, či externý súbor zodpovedá očakávanému hashu, a v opačnom prípade ho neprijat – užitočné je najmä pri knižniciach z externých serverov, lebo útok môže vzniknúť práve nenápadnou úpravou legitímneho súboru [5].

Súčasťou ochrany musí byť pravidelný monitoring zmien na platobných stránkach – zmenený skript, nová externá doména alebo neznámy kód môžu byť signálom začínajúceho e-skimmingového útoku [11]. K technickým opatreniam patria aj pravidelné aktualizácie e-commerce platformy, pluginov a knižníc; OWASP Top 10 Client-Side Security Risks upozorňuje na zraniteľné a zastarané komponenty na strane klienta [12]. Vhodné je tiež oddeliť platobný proces od marketingových a analytických funkcií – čím menej externých prvkov beží na platobnej stránke, tým menší je priestor na kompromitáciu cez tretiu stranu, čo potvrdzujú aj analyzované prípady.

9.3 Organizačné opatrenia a riadenie rizík

Prevencia nie je iba technickou úlohou, ale aj otázkou riadenia rizík. Prevádzkovateľ má mať prehľad o tom, kto má prístup k administrácii, kto môže meniť skripty, kto schvaľuje nové externé služby a ako sa kontroluje ich bezpečnosť. FBI upozorňuje, že útočníci získavajú prístup aj cez phishing voči zamestnancom alebo cez zraniteľného dodávateľa tretej strany [3]. S tým súvisí kontrola dodávateľov: externé skripty, chatboty, analytika či pluginy musia byť pred nasadením na platobné stránky posúdené z hľadiska bezpečnostného rizika, nielen funkcionality. Ticketmaster ukazuje, že zanedbanie tohto rizika vedie k vážnemu incidentu a regulačnej sankcii [9].

Organizácia musí mať pripravený plán reakcie na incident – pri podozrení rýchlo identifikovať rozsah kompromitácie, odstrániť kód, skontrolovať platobnú stránku a komunikovať s bankami a partnermi. Pri incidentoch s osobnými údajmi môže vzniknúť aj povinnosť oznámenia dozornému orgánu alebo dotknutým osobám podľa GDPR [16]. Bezpečnostné testovanie musí zahŕňať aj kontrolu načítaných skriptov, sieťovej komunikácie a správania checkout procesu – stránka môže pre používateľa fungovať bežne a zároveň odosielať údaje na neznámu doménu, takže testovanie sa nemôže obmedziť na serverovú časť [11, 12]. Doplnkom je školenie zamestnancov: silné heslá, viacfaktorové overenie a obozretnosť voči phishingu znižujú pravdepodobnosť, že útočník získa prvotný prístup [3].

9.4 Opatrenia z pohľadu zákazníka

Hlavná zodpovednosť leží na prevádzkovateľovi, ale určitú mieru ochrany môže uplatniť aj zákazník: kontrolovať pohyby na účte, používať oznámenia o platbách, pri podozrivých transakciách kontaktovať banku a podľa možnosti využívať jednorazové či virtuálne karty, nižšie limity pre online platby a metódy s dodatočným potvrdením transakcie. Tieto opatrenia útoku nezabraňujú, len znižujú škodu po kompromitácii. Analyzované prípady ukazujú, že obeťou web skimmingu sa môžu stať aj zákazníci veľkých služieb, takže skutočná prevencia leží predovšetkým na prevádzkovateľoch e-shopov, platobných stránok a poskytovateľoch externých služieb.

9.5 Prehľad ochranných opatrení

9.6 Zhrnutie ochrany

Účinná ochrana kombinuje technické, organizačné a procesné opatrenia: technické chránia integritu skriptov a obmedzujú externé zdroje, organizačné riešia prístupy, dodávateľov, školenie a reakciu na incident, procesné zabezpečujú, aby sa ochrana

Tabuľka 5: Prehľad ochranných opatrení proti web skimmingu

Opatrenie	Význam pri ochrane proti web skimmingu
Autorizácia skriptov na platobnej stránke	Prevádzkovateľ vie, ktoré skripty sú povolené a prečo sa na stránke spúšťajú.
Kontrola integrity skriptov	Pomáha odhaliť, či sa externý alebo interný skript zmenil bez schválenia.
Monitoring zmien platobnej stránky	Umožňuje zistiť neoprávnené úpravy stránky alebo pridaný škodlivý kód.
Obmedzenie skriptov tretích strán	Znižuje riziko kompromitácie cez externého dodávateľa alebo službu.
Content Security Policy	Obmedzuje zdroje, z ktorých môže stránka načítavať obsah a s ktorými môže komunikovať.
Subresource Integrity	Overuje, či načítaný externý súbor zodpovedá očakávanému obsahu.
Aktualizácia platformy a pluginov	Znižuje riziko zneužitia známych zraniteľností.
Bezpečnostné testovanie checkout procesu	Pomáha odhaliť podozrivé správanie klientského kódu a externú komunikáciu.
Riadenie dodávateľov	Zabezpečuje, že externé služby používané na platobnej stránke sú posúdené z hľadiska rizika.
Plán reakcie na incident	Umožňuje rýchlu reakciu pri zistení kompromitácie platobnej stránky.

platobnej stránky nekončila jednorazovou kontrolou. Najdôležitejšou myšlienkou je, že platobná stránka je vysoko citlivá časť webovej aplikácie – nestačí, aby vyzerala dôveryhodne a používala HTTPS. Musí byť jasné, aký kód sa na nej spúšťa, kto ho dodáva, či bol autorizovaný a či sa nezmenil. Web skimming využíva práve priestor medzi dôverou zákazníka v legítimnu stránku a nedostatočnou kontrolou klientskeho kódu.

10 Záver

Web skimming je špecifickou formou počítačovej kriminality, v ktorej sa technická manipulácia webovej stránky spája s priamym finančným zneužitím. Na rozdiel od viditeľnejších útokov nespôsobuje výpadok, zničenie dát ani zmenu vzhľadu – jeho nebezpečnosť spočíva v nenápadnosti. Zákazník môže používať legitímnu stránku známeho obchodníka, úspešne dokončiť objednávku a pritom prísť o platobné údaje odcudzené škodlivým skriptom.

Cieľom práce bolo vysvetliť web skimming, opísať jeho technický princíp a kriminálnu podstatu a porovnať vybrané prípady. Z teoretickej časti vyplýva, že podstatou útoku je zneužitie klientského prostredia, najmä JavaScriptu v prehliadači používateľa – útok nemusí cieľiť na databázu ani platobnú bránu, stačí dostať škodlivý kód na stránku, kde zákazník zadáva citlivé údaje. Prípadové štúdie ukázali viacero podôb javu: British Airways predstavuje veľký incident s výraznými právnymi a reputačnými následkami, Ticketmaster ukazuje riziko skriptov tretích strán v platobnom procese a Newegg je technicky jasný príklad Magecart útoku na checkout stránku. Spoločným znakom je zneužitie dôvery v legitímnu online službu.

Ochrana sa preto nemôže obmedziť na klasickú serverovú bezpečnosť. Nutná je kontrola klientského kódu, externých skriptov, integrity zdrojov a komunikácie platobnej stránky s externými doménami – prevádzkovateľ musí vedieť, čo sa na platobnej stránke reálne spúšťa a či je každý prvok potrebný, autorizovaný a monitorovaný. Z kriminálneho hľadiska je web skimming závažný tým, že ukradnuté údaje majú priamu ekonomickú hodnotu a dopad sa týka nielen prevádzkovateľa, ale aj zákazníkov, bánk a regulačných orgánov.

Najdôležitejším záverom je, že platobná stránka je kritickou časťou webovej aplikácie. Nestačí, aby pôsobila dôveryhodne a používala HTTPS – potrebná je aktívna kontrola skriptov, obmedzenie zbytočných tretích strán, monitorovanie zmien a pripravenosť na incident. Web skimming ukazuje, že moderná kyberkriminalita často neútočí hlučne, ale ticho využíva dôveru používateľov a slabé miesta v dodávateľskom reťazci webových aplikácií.

Literatúra

1. CISA. *E-Skimming: Skimming Online Customer Payment Data From Website Checkout Forms* [online]. 2020. [cit. 2026-04-29]. Dostupné z: https://www.cisa.gov/sites/default/files/publications/NCSAM_ESkimming_2020.pdf.
2. EUROPOL. *Digital Skimming* [online]. [cit. 2026-04-29]. Dostupné z: <https://www.europol.europa.eu/cms/sites/default/files/documents/Digital%20Skimming.pdf>.
3. FEDERAL BUREAU OF INVESTIGATION. *Oregon FBI Tech Tuesday: Building a Digital Defense Against E-Skimming* [online]. 2019-10-22. [cit. 2026-04-29]. Dostupné z: <https://www.fbi.gov/contact-us/field-offices/portland/news/press-releases/oregon-fbi-tech-tuesday-building-a-digital-defense-against-e-skimming>.
4. OWASP FOUNDATION. *Third Party Javascript Management Cheat Sheet* [online]. [cit. 2026-04-29]. Dostupné z: https://cheatsheetseries.owasp.org/cheatsheets/Third_Party_Javascript_Management_Cheat_Sheet.html.
5. OWASP FOUNDATION. *Subresource Integrity* [online]. [cit. 2026-04-29]. Dostupné z: <https://owasp.org/www-community/controls/SubresourceIntegrity>.
6. EUROPOL. *Action Against Digital Skimming Reveals 443 Compromised Online Merchants* [online]. 2023-12-22. [cit. 2026-04-29]. Dostupné z: <https://www.europol.europa.eu/media-press/newsroom/news/action-against-digital-skimming-reveals-443-compromised-online-merchants>.
7. EUROPEAN DATA PROTECTION BOARD. *ICO Statement: Intention to Fine British Airways £183.39m Under GDPR for Data Breach* [online]. 2019-07-08. [cit. 2026-04-29]. Dostupné z: https://www.edpb.europa.eu/news/national-news/2019/ico-statement-intention-fine-british-airways-ps18339m-under-gdpr-data_en.
8. GDPR REGISTER. *ICO Fines British Airways £20m for Data Breach Affecting More Than 400,000 Customers* [online]. 2020-10-16. [cit. 2026-04-29]. Dostupné z: <https://www.gdprregister.eu/articles/british-airways-fine/>.
9. INFORMATION COMMISSIONER'S OFFICE. *Penalty Notice: Ticketmaster UK Limited* [online]. 2020-11-13. [cit. 2026-04-29]. Dostupné z: https://www.edpb.europa.eu/sites/default/files/article-60-final-decisions/uk_2020-11_personal_data_breach_decisionpublic_final.pdf.

10. VOLEXITY THREAT RESEARCH. *Magecart Strikes Again: Newegg in the Crosshairs* [online]. 2018-09-19. [cit. 2026-04-29]. Dostupné z: <https://www.volexity.com/blog/2018/09/19/magecart-strikes-again-newegg/>.
11. PCI SECURITY STANDARDS COUNCIL. *New Information Supplement: Payment Page Security and Preventing E-Skimming* [online]. 2025-03-10. [cit. 2026-04-29]. Dostupné z: <https://blog.pcisecuritystandards.org/new-information-supplement-payment-page-security-and-preventing-e-skimming>.
12. OWASP FOUNDATION. *OWASP Top 10 Client-Side Security Risks* [online]. [cit. 2026-04-29]. Dostupné z: <https://owasp.org/www-project-top-10-client-side-security-risks/>.
13. BROADCOM / SYMANTEC. *Formjacking* [online]. [cit. 2026-04-29]. Dostupné z: <https://docs.broadcom.com/docs/istr-formjacking-deep-dive-en>.
14. FORTINET. *An Analysis of Magecart Skimmer Attacks* [online]. 2019-05-30. [cit. 2026-04-29]. Dostupné z: <https://www.fortinet.com/blog/threat-research/payment-card-details-stolen-magecart>.
15. SLOVENSKÁ REPUBLIKA. *Zákon č. 300/2005 Z. z. Trestný zákon* [online]. 2005-05-20. [cit. 2026-04-29]. Dostupné z: <https://www.slov-lex.sk/ezbierky/pravne-predpisy/SK/ZZ/2005/300/>.
16. EURÓPSKA ÚNIA. *Nariadenie Európskeho parlamentu a Rady (EÚ) 2016/679, všeobecné nariadenie o ochrane údajov* [online]. 2016-04-27. [cit. 2026-04-29]. Dostupné z: <https://eur-lex.europa.eu/legal-content/SK/TXT/?uri=CELEX:32016R0679>.
17. SIMMONS & SIMMONS. *British Airways Penalty Notice: the download* [online]. 2020-10-22. [cit. 2026-04-29]. Dostupné z: <https://www.simmons-simmons.com/en/publications/ckgkwyif32y0n09447bd3j12l/british-airways-penalty-notice-the-download>.

Použitie nástrojov umelej inteligencie

OpenAI (2026), Codex, pomoc pri technickej úprave dokumentu, kontrole formátu citácií, doplnení bibliografických záznamov a redakčnej úprave textu.

OpenAI (2026), ChatGPT-5.5, použitý ako pomocný nástroj na sumarizáciu verejne dostupných zdrojov, jazykové preformulovanie a orientačné zhromaždenie podkladov k téme web skimmingu. Odborné rozhodnutia, výber obsahu, vlastné myšlienky, interpretácie a konečné znenie práce sú výsledkom práce autora.